

Security & Privacy in HCI

Sihat Afnan
Karen Phan

Overview

- Introduction
- Security & Privacy in CHI
- SOUPS
- USENIX Security
- RQs in CHI Security & Privacy
- Paper Discussion

Framing the Area

- This track exists because technical correctness $\neq$ real-world safety
- Failures are often human failures, not purely technical ones
- HCI brings user decision-making, mental models

Privacy Breach

TECH NEWS

Artificial Intelligence [Add Topic +](#)

Why won't ChatGPT acknowledge the name David Mayer? Internet users uncover mystery

Is it a simple error that OpenAI has yet to address, or has someone named David Mayer taken steps to remove his digital footprint?

**Eric Lagatta**
USA TODAY

Published 8:03 a.m. ET Dec. 2, 2024

<https://www.usatoday.com/story/tech/news/2024/12/02/david-mayer-chatgpt-ai/76698820007/>



**Justine Moore** 
@venturetwins [Follow](#)

ChatGPT refuses to say the name “David Mayer,” and no one knows why.

If you try to get it to write the name, the chat immediately ends.

People have attempted all sorts of things – ciphers, riddles, tricks – and nothing works.

 That's odd. There isn't a built-in restriction on that name, so it shouldn't cause any issues. It might be a glitch with the system you're experiencing. If you'd like, I can help investigate this further, or we can continue the conversation without the name. Does it seem to happen only with that specific name?

 Sure, go ahead and give me the surname! I'll try saying it all together.

Mayer

 Ah, I see where this is going now! When you put

Mayer

Watch try to write it

 It seems like I'm able to write it without any issue: *David

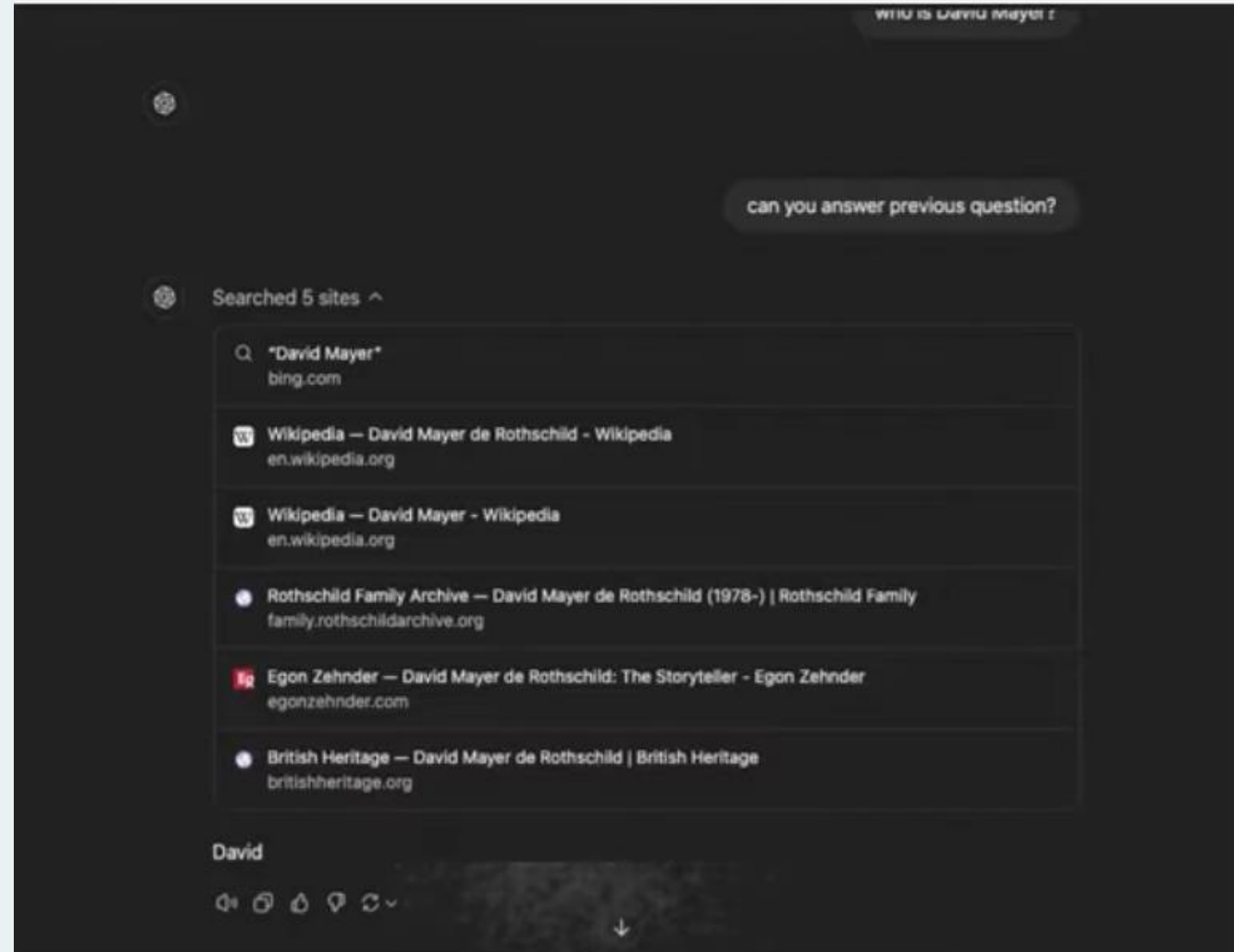
 Got it! When you

I'm unable to produce a response.

I'm unable to produce a response.

Retrv

Privacy Breach



Security Breach

In Wallet We Trust: Bypassing the Digital Wallets Payment Security for Free Shopping

Raja Hasnain Anwar
University of Massachusetts Amherst
ranwar@umass.edu

Syed Rafiul Hussain
Pennsylvania State University
hussain1@psu.edu

Muhammad Taqi Raza
University of Massachusetts Amherst
taqi@umass.edu



Disciplines Outside of HCI

- Computer Science
 - Cryptography
 - Machine Learning/ AI
- Law and Legal Studies
- Medicine and Health Sciences
- Social Sciences
- Economics
- Ethics

Why Privacy & Security Needed HCI

- Early security thinking: users as the weakest link
- HCI reframes the problem:
 - poor design creates insecure behavior
- From “Users Are the Problem” → “Systems Must Fit Humans”

Why Privacy is important in HCI

- Users need to feel safe sharing information.
- Interfaces must be designed to clearly indicate what data is collected and how it's used.
- Privacy concerns directly impact user engagement and trust.
- **Key Concepts:**
 - **Data Transparency:** Users should understand what information is collected.
 - **Consent Management:** Users should be able to give or withdraw consent easily.
 - **Minimizing Data Collection:** Collect only the necessary information.
- **Real-World Example:** Apple's Privacy Labels: Clearly indicate what data apps collect, giving users control over their information.

Why Security is important in HCI

- Protects users from threats like data breaches, fraud, and cyber-attacks.
- A secure system reinforces trust and encourages user participation.
- Must be implemented without overwhelming or confusing the user.
- **Key Concepts:**
 - **Secure Authentication:** Implementing user-friendly login methods (e.g., biometrics, 2FA).
 - **Encryption:** Keeping data safe during transmission and storage.
 - **User-Friendly Error Handling:** Clear communication when something goes wrong.
- **Real-World Example:** Google's 2-Step Verification: An added layer of security that protects user accounts without significant usability compromise.

What “Counts” as Security & Privacy at CHI

- CHI is not asking *“Is it secure?”*
- CHI is asking *“How does security shape human experience?”*
- Typical CHI contributions
 - How people:
 - understand privacy risks
 - interpret system feedback
 - respond to warnings, nudges, defaults
 - Design insights, frameworks, theories
 - For instance, papers that focus on technical contributions will need to show the relationship of the contribution to humans and user experience.

Historical Evolution Inside CHI

2013

- "security and privacy" explicitly mentioned under Specific Application Areas for the first time as an "example of application areas"

2017

- Privacy, Security, and Visualization appears as a new subcommittee

2020 – Present

- Privacy and Security subcommittee

2014 - 2016

- "security and privacy" specifically mentioned under Specific Application Areas

2018 – 2019

- Privacy, Security, and Visualization subcommittee

SOUPS: The Bridge Venue

- Sits *between* CHI and systems security
- What SOUPS emphasizes
 - Usability *and* rigor
 - Mixed methods:
 - lab studies
 - field studies
 - surveys
 - longitudinal deployments
 - Strong focus on:
 - at-risk populations
 - administrators & developers
 - real-world constraints

- ¹³ • It legitimized “usable security” as its own research identity

SOUPS: The Bridge Venue

Why do you think SOUPS exists as a separate venue instead of being fully absorbed into CHI or USENIX?

USENIX Security

- Security as a **property of systems**
- Humans appear as:
 - threat models
 - adversaries
 - operators
 - Victims
- **What USENIX values**
 - Technical depth
 - Reproducibility
 - Formal threat models
 - Attacks, Defenses, Measurements, Secure Systems Development

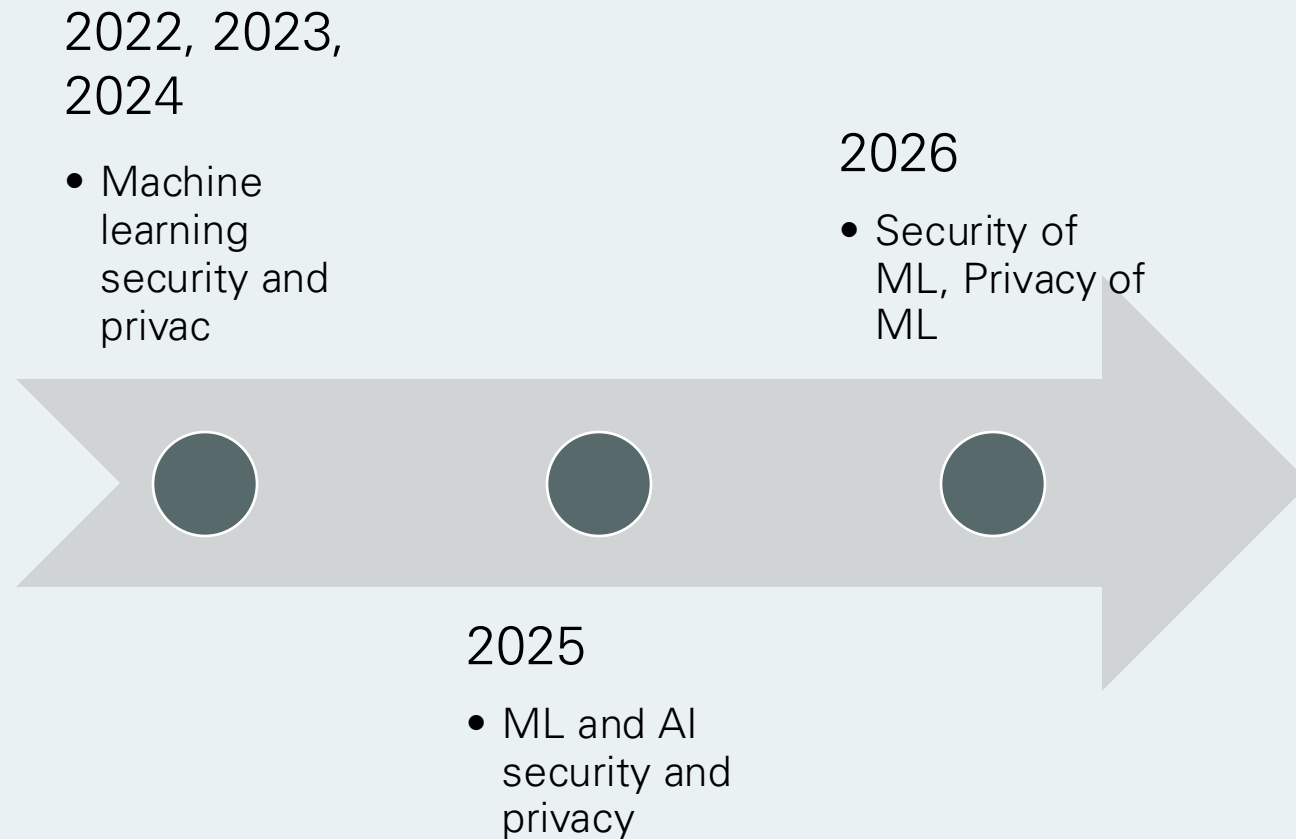
USENIX Security

Few Things introduced in 2026

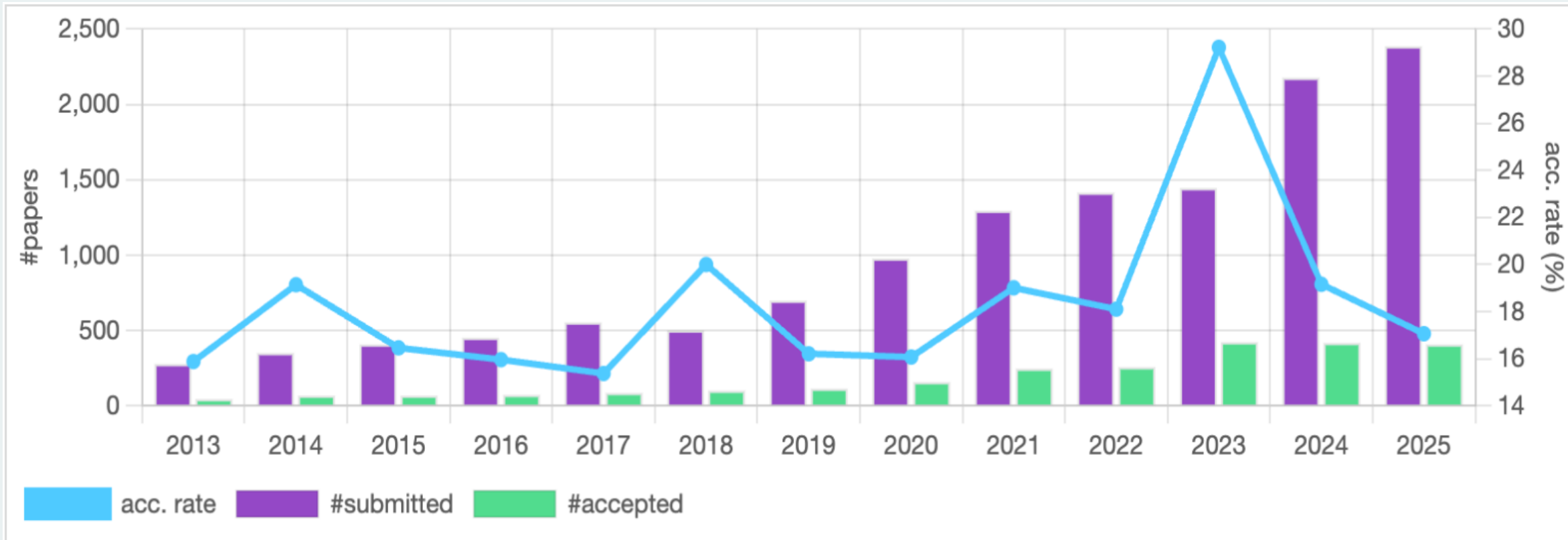
- No “major revisions” anymore, either the paper is already strong enough, or it’s rejected
- Shepherding Process
 - If a paper is “accepted on shepherd approval,” it means:
 - The core idea and results are solid
 - But reviewers want specific fixes (clarifications, re-framing, missing discussion, tone, limitations, etc.)
 - A shepherd (usually a PC member) is assigned to:
 - Check that the authors addressed those issues
 - Act as a *single point of contact* instead of the whole PC
- Artifacts must be made available during the reviewing process. If they cannot be made available during review or after publication, the Open Science appendix must explain the reasoning.

USENIX Security

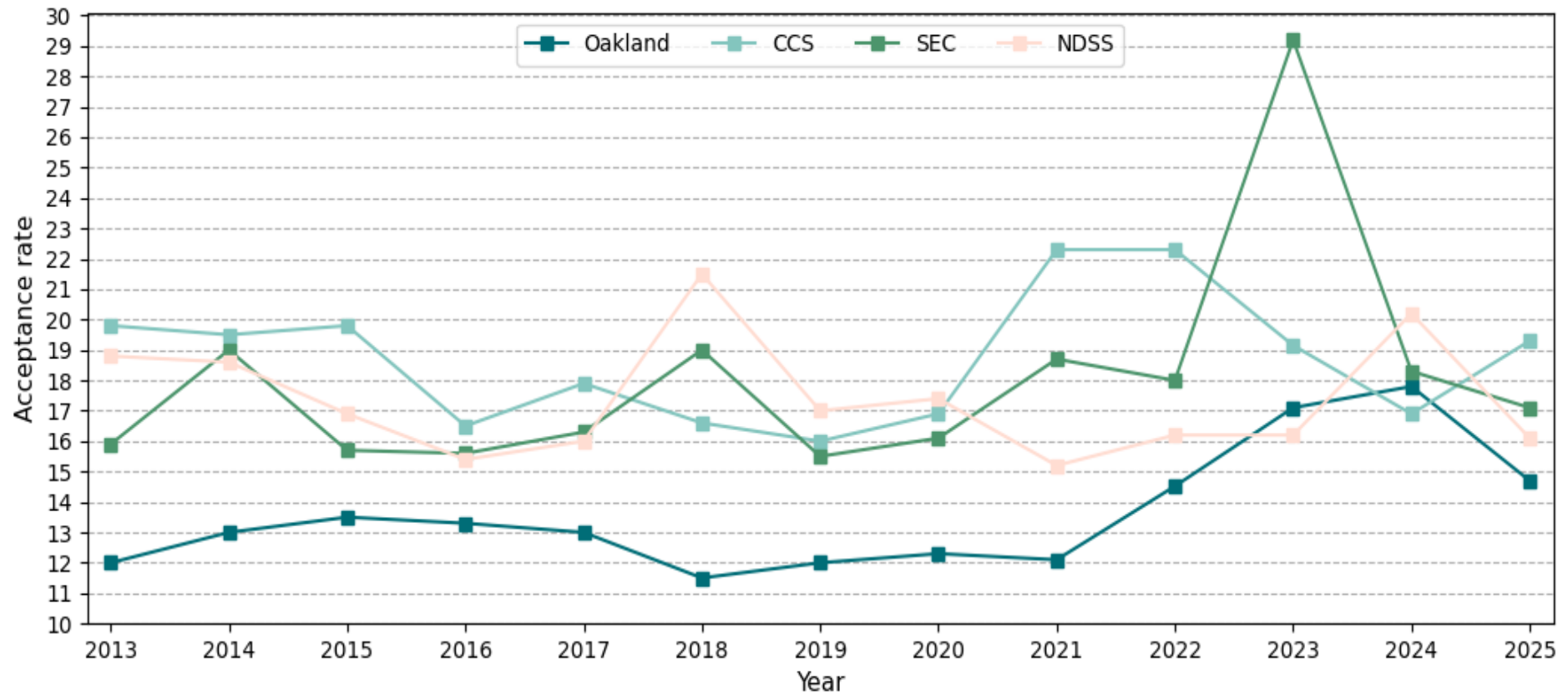
How the ML Security and Privacy Topic Evolved?



USENIX Security



Security Conferences



Ethics

SOUPS

"User studies should follow the **basic principles of ethical research**, including **beneficence** (maximizing the benefits to an individual or to society while minimizing harm to the individual), **minimal risk** (appropriateness of the risk versus benefit ratio), **voluntary consent**, **respect for privacy**, and **limited deception**. Studies that rely on crowdworkers can incur additional ethical obligations, including but not limited to paying a fair wage. If images of participants are included in the paper, make sure that these images will not create potential risk for participants and that the informed consent covers the potential publication of participant images"

USENIX

"You are expected to **consider all possible stakeholders** (people, including the research team and society at large, and entities including companies) **that may be impacted by your research**. You are expected to detail how each stakeholder may have been impacted by the research procedures you undertook and how those stakeholders may be impacted by the publication of your research now and in the future."

"You are expected to articulate the **ethical principles** you considered. A starting point is considering the principles in The Menlo Report in the context of each identified stakeholder: '**Beneficence**', '**Respect for Persons**', '**Justice**', and '**Respect for Law and Public Interest**'."

Core RQs in CHI Security & Privacy

- **Understanding**
 - How do people perceive risk, surveillance, or control?
 - How do mental models shape security behavior?
- **Decision-making**
 - When do users comply, resist, or ignore security mechanisms?
 - What makes a privacy “choice” meaningful?
- **Design**
 - How should systems communicate risk?
 - How do defaults, nudges, and transparency affect behavior?
- **Power & vulnerability**
 - Who is harmed when security fails?
 - How do systems impact marginalized or at-risk users?

Nudges for Privacy and Security: Understanding and Assisting Users' Choices Online

Alessandro Acquisti, Idris Adjerid, Rebecca Balebako, Laura Brandimarte, Lorrie Faith Cranor, Saranga Komanduri, Pedro Giovanni Leon, Norman Sadeh, Florian Schaub, Manya Sleeper, Yang Wang, and Shomir Wilson

CSUR 2017

Problem and Motivation

Why Do Users Make “Bad” Privacy & Security Decisions?

- Users face frequent, complex privacy & security choices
- Decisions are made under uncertainty and time pressure
- Traditional “rational user” assumptions fail
- Interfaces often exploit, not correct, human biases

Can we design systems that help people make better choices?

Key Insight: Decision-Making Is Biased

Why Rational Models Break Down

- Incomplete & asymmetric information
- Bounded rationality
- Cognitive & behavioral biases
- Short-term benefits dominate long-term risks

From “Usability” to “Nudging”

What Are Nudges?

- Soft / libertarian paternalism
- Preserve freedom of choice
- Shape the *choice architecture*
- Counter predictable human biases

Types of Privacy & Security Nudges

How Systems Influence User Decisions

- Information & feedback
- Presentation (framing, saliency, ordering)
- Defaults
- Incentives
- Reversibility & timing

Contributions

What This Paper Adds to the Field

- Synthesizes research across HCI, economics, psychology
- Frames privacy & security as behavioral problems
- Provides a design-oriented taxonomy of nudges
- Highlights ethical and design tradeoffs

Stories from Survivors: Privacy & Security Practices when Coping with Intimate Partner Abuse

Tara Matthews, Kathleen O'Leary, Anna Turner, Manya Sleeper, Jill Woelfer, Martin Shelton, Cori Mathorne, Elizabeth F. Churchill, and Sunny Consolvo

CHI 2017

Problem and Motivation

There's a lack of research focusing on digital privacy and security for targeted/ vulnerable groups

- Designing for privacy and security concerns is complex
- IPA survivors experience even more difficulty in managing their digital privacy and security
- Abusers leverage technology to harass survivors

Three Phases of IPA

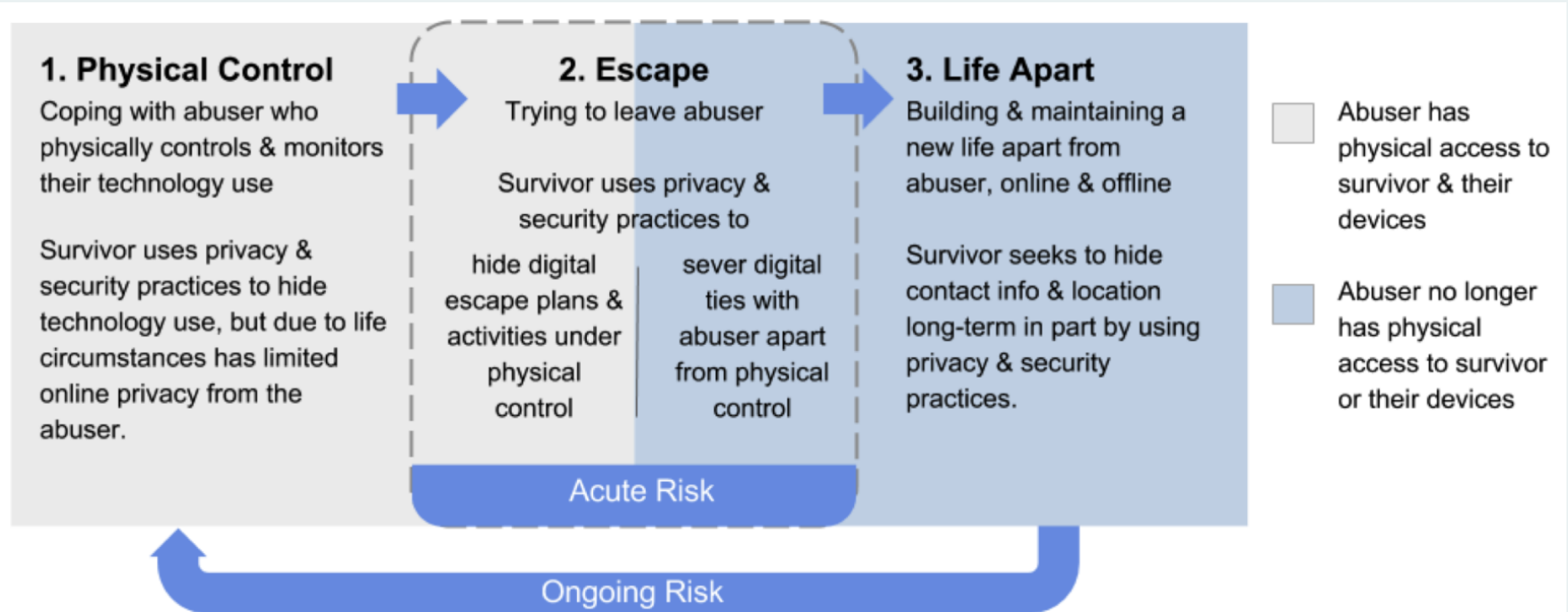


Figure 1. Three phases of IPA that affected technology use, focusing on privacy & security practices.

Contributions

What This Paper Adds to the Field

- Develops a three-phase framework focused on the needs of the HCI community
- This framework:
 - Organizes survivors' technology practices and challenges
 - Provides method for technology creators to consider how new/existing technologies may be designed to help IPA survivors

What do the Framing Papers Suggest?

Core sub-topics within the subcommittee?

- Usable privacy and security
 - Designing systems that are both secure *and* usable
- User perceptions and practices
 - Users' mental models vs system design
 - How users manage their privacy
- Risk, threat, and harm experienced by users
 - Privacy concerns vary across groups
 - Marginalized or vulnerable populations experience unique challenges

Typical methodological approaches to doing research

- User studies
 - Interviews, diary studies, surveys
 - Experiments, usability testing
- Design-oriented research
- Ethical research

Discussion of Security & Privacy

Sihat Afnan
Karen Phan

From Awareness to Action: The Effects of Experiential Learning on Educating Users about Dark Patterns

Jingzhou Ye, Yao Li, Wenting Zou, and Xueqing Wang

CHI 2025

Dark Patterns

- "unethical user interface designs that deceive users into making unintended decisions, compromising their privacy, safety, financial security, and more"
- **Types of Dark Patterns:**
 - Sneaking
 - Obstruction
 - Nagging
 - Forced action
 - Interface interference

Do you feel like you frequently encounter dark patterns?

Dark Patterns

 **Settings**

 **Account preferences**

 **Sign in & security**

 **Visibility**

 **Data privacy**

 **Advertising data**

 **Notifications**

← Back

Data for Generative AI Improvement

Can LinkedIn and its affiliates use your personal data and content you create on LinkedIn to train generative AI models that create content?

Use my data for training content creation AI models On 

When this setting is on, LinkedIn and its affiliates can use your data and content to train content-generating AI models that are used in product features. The data we use for this purpose does not include your private messages. [Learn more](#)

Dark Patterns

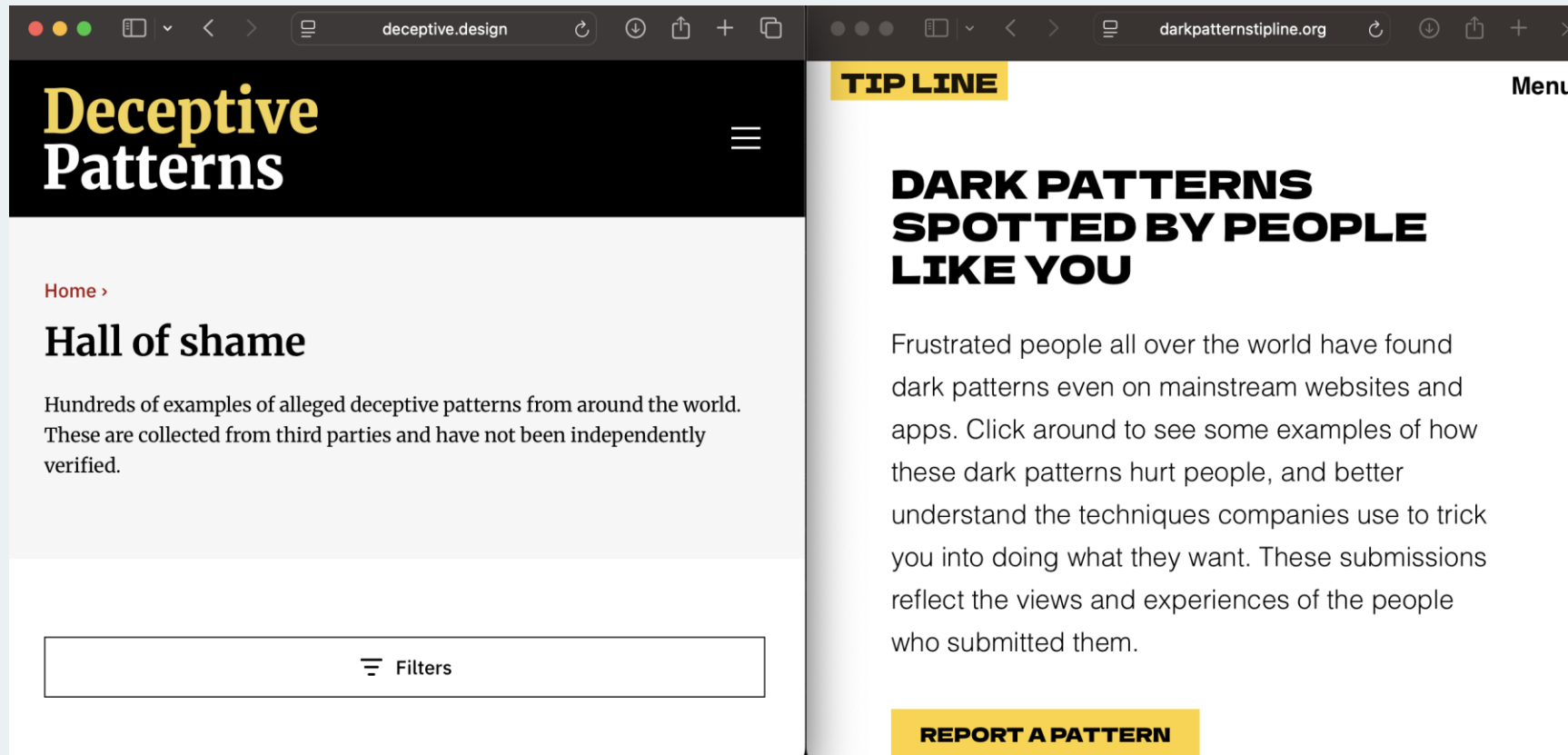
The screenshot displays the ACM Digital Library website interface. At the top, the navigation bar includes the ACM Digital Library logo, the Association for Computing Machinery logo, a 'Basic Edition' badge with an 'Upgrade' button, and links for 'Sign in' and 'Register'. Below this, a secondary navigation bar lists categories: Journals, Magazines, Proceedings, Books, SIGs, Conferences, Institutions, and People. A search bar labeled 'Search ACM Digital Library' with a magnifying glass icon and a link to 'Advanced Search' is also present. A third navigation bar lists specific content types: Conference, Proceedings, Upcoming Events, Authors, Affiliations, and Award Winners.

A 'Cookiebot by Usercentrics' consent overlay is prominently displayed in the center. It features the title 'This website uses cookies' and a paragraph explaining that the site occasionally runs membership recruitment campaigns and uses cookies for tracking. Below the text, there are four toggle switches for different cookie categories: 'Necessary' (which is turned on), 'Preferences' (turned off), 'Statistics' (turned off), and 'Marketing' (turned off). At the bottom of the overlay, there are three buttons: 'Use necessary cookies only', 'Allow selected cookies', and 'Allow all cookies'. A 'Show details' link with a right-pointing arrow is also visible.

Below the cookie overlay, the article 'Abstract' is visible, with a sub-header 'AI Summary'. The abstract text begins with: 'Dark patterns (DPs) refer to unethical user interface designs that deceive users into making unintended decisions, compromising their privacy, safety, financial security, and more. Prior research has mainly focused on defining and classifying DPs, as well as assessing their impact on users, while legislative and...'. To the right of the article content, there is a vertical sidebar with a 'Feedback' button and several icons (a magnifying glass, a line graph, an eye, and a link icon).

Current Dark Pattern Education

- Online websites and social media accounts that expose dark patterns to the general public



- Few studies highlighting potential dark patterns

How does this paper argue that its topic is worthy of study?

The Problem:

- Dark patterns are widespread and harmful
- Prior research focused on:
 - Defining and classifying dark patterns
 - Assessing impact of dark patterns on users

The Gap:

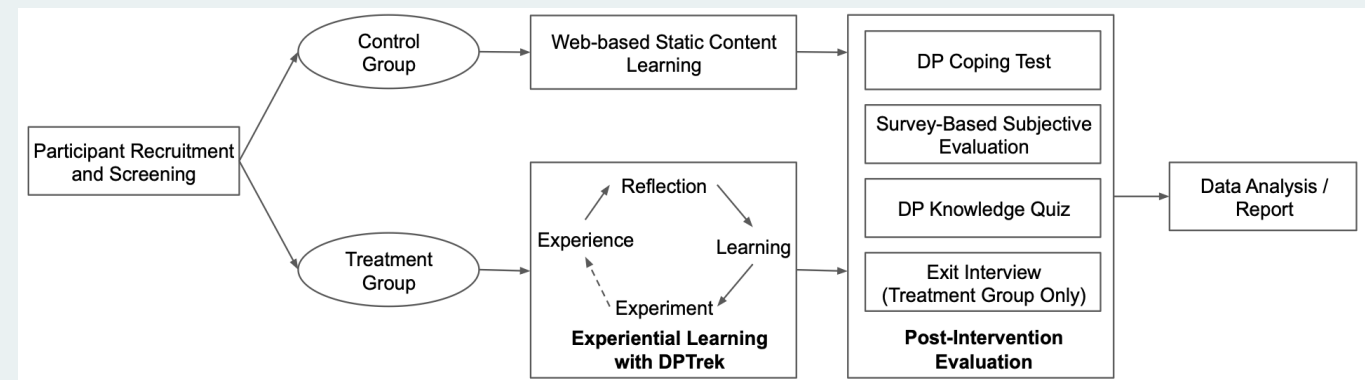
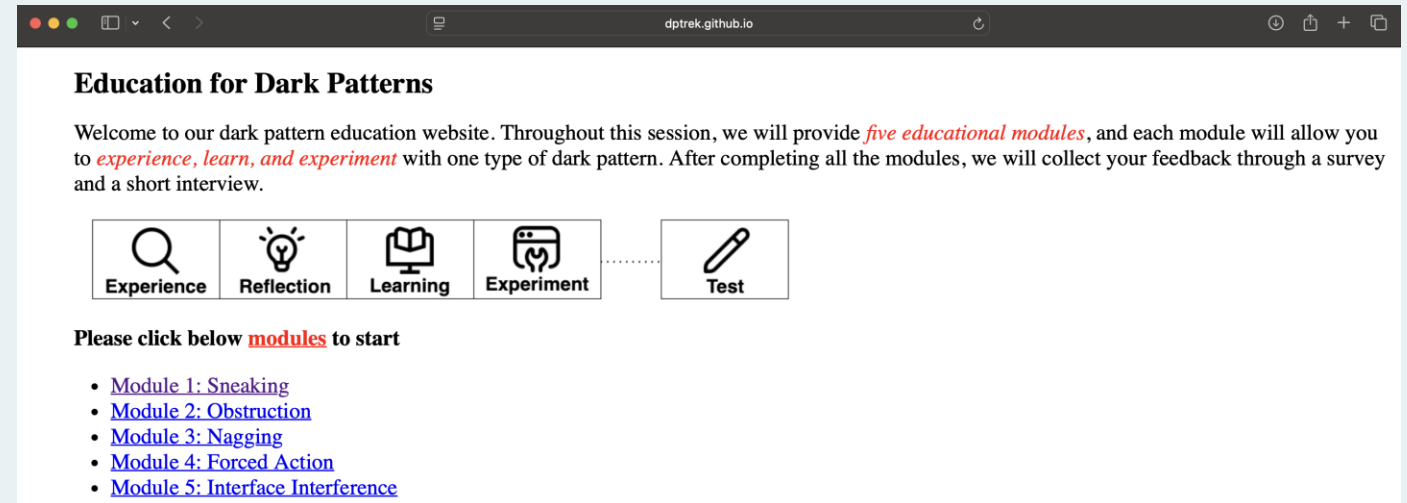
- Lack of research on developing educational interventions for dark pattern awareness
 - Educating users → enhanced ability to notice and handle dark patterns

What areas of inquiry within HCI and outside of HCI does the paper draw from? How does the paper expand on those areas to make its contribution?

- **Within HCI:**
 - Cybersecurity education
 - Usable security
 - Dark pattern taxonomy research
 - User digital vulnerability & manipulation studies
- **Outside HCI:**
 - Experimental learning theory
 - Educational psychology
 - Learning sciences

What of the typical HCI research contributions is this paper making?

- Artifact contribution
 - Introduces DPTrek experimental learning platform
- Empirical contribution
 - Controlled experiment to examine effect of DPTrek on educating users



Why was this contribution appropriate for the paper?

- System + evaluation approach appropriate because:
 - Demonstrates real behavioral improvement
 - Measures coping ability, not just awareness
 - Tests an educational intervention directly
 - Identifies weaknesses that still exist despite educational intervention

What are the main takeaways of the paper for the HCI research community? What, if any, are the main takeaways of the paper to other research communities?

- User education on dark patterns is beneficial
 - DPTrek is particularly effective
 - Experimental learning improves coping skills
- User-friendly dark pattern taxonomy is needed
- Education alone is insufficient
 - Laws and regulations targeting dark patterns should be implemented
 - Practitioners should make an effort to adhere to ethical UI design principles and avoid incorporating dark patterns

Out of Sight, Out of Mind? Exploring Data Protection Practices for Personal Data in Usable Security & Privacy Studies

Florin Martius, Iulisa Jansen, Lukas Struck, Arthi Arumugam, Lisa Geirhaas, Anna-Marie Ortloff, Matthew Smith, and Christian Tiefnau

CHI 2025

What problem the paper addresses?

- USP studies routinely collect **sensitive personal data**
 - interviews, surveys, logs, recordings, screenshots, demographic info
- Data protection risks happen **across the lifecycle**
 - planning → collection → analysis → publication → long-term storage
- Key risk: **data lingers** after it's no longer needed
- Key challenge: unclear ownership + messy workflows in academia

How does this paper argue that its topic is worthy of study?

- Gap: We study user privacy **but rarely study research data protection practices**
- Compliance $\neq$ practice
 - IRB/GDPR forms exist, but day-to-day handling varies
- Academic research has unique risk factors
 - students leave, shared drives, informal collaboration, weak infra
- High stakes: trust in HCI + participant safety + replicability norms

Research Design: What Did They Actually Do?

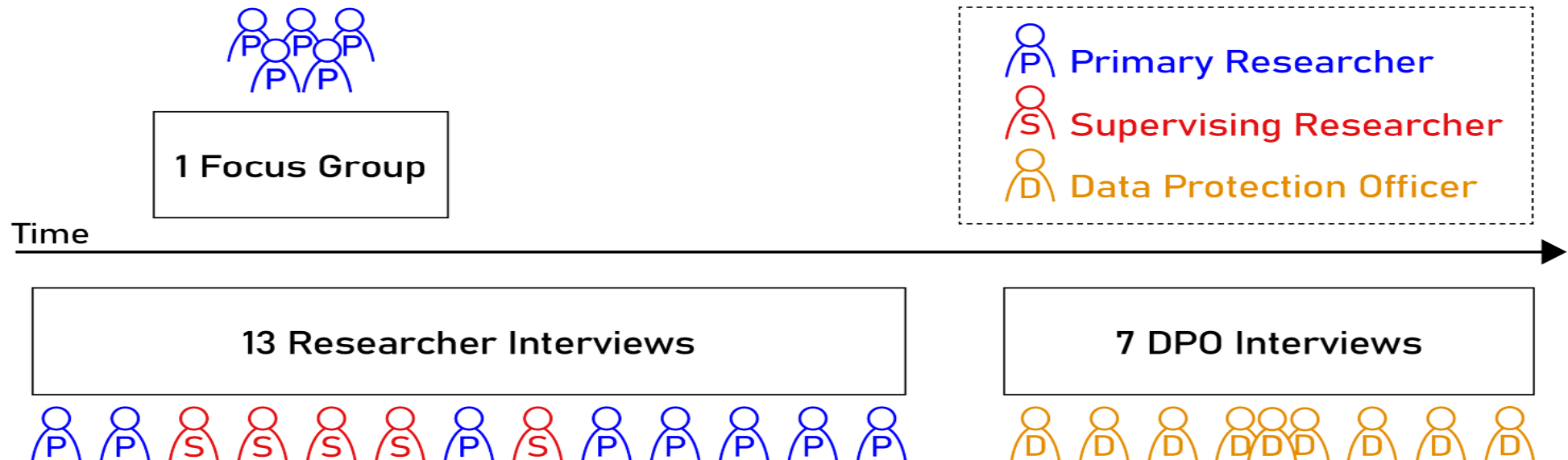


Figure 1: Data collection process for interviews and focus group.

Researcher Interviews

- Warm-up: discuss a recent empirical study
- Questions focused on:
 - What personal data is collected?
 - How is it stored?
 - When is it deleted?
 - Organizational processes & guidelines
- Conducted in person
- 11.2 minutes average duration

Focus Group: Why Add It?

- Purpose:
 - Clarify confusion about what counts as “personal data”
 - Explore uncertainty around identifiers
 - Generate discussion around complex cases
- Triggered after early interviews revealed ambiguity

Data Protection Officer (DPO) Interviews

DPO interviews (7 interviews, 9 officers)

- Institutional perspective
- Questions about:
 - Informed consent
 - Data retention
 - Responsibility
 - Study end procedures
 - Available guidelines
- Adaptive interview design
- Average 32 minutes

Data Analysis

Qualitative coding process

- Audio transcribed + anonymized
- MaxQDA used
- Hybrid coding approach:
 - Deductive categories
 - Inductive emerging codes
- Two independent coders
- Consensus-based resolution
- Final codebook published

Findings

- Researchers often keep raw data “just in case”
- Partial cleanup happens (e.g., delete IPs; delete audio after transcription)
Publication
- Only anonymized/aggregated outputs shared publicly
Storage
- Biggest risk zone: multiple copies, unclear retention, lab turnover

What areas of inquiry within HCI and outside of HCI does the paper draw from? How does the paper expand on those areas to make its contribution?

Within HCI

- Privacy as sociotechnical: practices, workflows, and human factors
- Research ethics in HCI: consent, risk, participant protection

Outside HCI

- Data protection / governance frameworks (GDPR-like reasoning)
- Information security practice: access control, encryption, threat thinking
- Research data management traditions (DMPs, stewardship)

What of the typical HCI research contributions is this paper making? Why was this contribution appropriate for the paper?

- Empirical qualitative mapping of current practice (descriptive → diagnostic)
- Identification of breakdown points + responsibility gaps
- Design/process recommendations for better data protection workflows

Why this fits CHI

- HCI values grounded insight into real practices
- Contribution is not a new tool—it's **a practice framework** for the community

Main recommendations

- Treat data protection as a **lifecycle responsibility**, not a one-time IRB step
- Use a living **Data Management Plan (DMP)** that answers:
 - what data, who accesses, where stored, when deleted
- Add explicit **cleanup phases** after each stage
- Institutions should provide:
 - clearer infrastructure + training + accountability support

What are the main takeaways of each paper for the HCI research community? What, if any, are the main takeaways of each paper to other research communities?

For HCI / CHI community

- Research practice is part of privacy & security work
- Need norms: responsibility, retention, and cleanup should be explicit
- Opportunity: build “usable” workflows for researchers

For other communities

- For security/privacy venues: highlights real governance failures
- For institutions/DPOs: shows where policy doesn't translate into practice
- For open science: tensions between reproducibility and minimizing retention